

CTO Call Preparation Binder

Line Axia — Olivia Aréchiga, CTO

Prepared for Jesse Lamont, Founder, Lamont Labs
CerbaSeal-Core v0.1.0 · 372 tests · 15/15 audit checks

CONTENTS

- 01 Where Is CerbaSeal Right Now?**
The VeraSeal question, current state, and pilot-ready gap
- 02 EU / Client-Controlled Deployment**
What is proven, what has not been executed, how to get there
- 03 Operational Role During A Pilot**
Onboarding, support, response times, and handover model
- 04 Realistic Capacity**
What the pilot actually costs in time, constraints, and honesty
- 05 Dependencies & Supply Chain**
Zero-dep core library — full corrected analysis
- 06 25 Follow-Up Questions**
Most likely questions with answers, risks, and phrases to avoid
- 07 Founder Cheat Sheet**
One-page pre-call reference: short / honest / danger answers

HOW TO USE THIS BINDER

Every answer in this document is sourced from the repository. No claims are invented or inflated. For each question: (1) the technical reality, (2) what it means in plain English, (3) what to say on the call, (4) likely follow-ups, and (5) risks to name honestly. If something is not in the code or docs, it is not in here.

WHERE IS CERBASEAL RIGHT NOW?

Olivia's Question: "Where is CerbaSeal relative to external deployment, specifically VeraSeal as the first component? What does pilot-ready mean and what is the gap between current state and that bar?"

CRITICAL — CORRECT THIS BEFORE ANYTHING ELSE

"VeraSeal" does not exist anywhere in this repository — not in source code, file names, tests, documentation, or comments. There is no component, module, or system by that name. If Olivia references VeraSeal, she has the name from another source. Correct it calmly and immediately: the enforcement core is CerbaSeal — specifically the ExecutionGateService. Then move on.

What CerbaSeal Is (Plain English)

CerbaSeal is a gatekeeper. When an AI-assisted system proposes an action — a payment, an approval, a process execution — CerbaSeal sits between the proposal and the execution and answers one question: should this be permitted right now? It checks who is asking, whether the required approvals exist, and whether the request satisfies a defined set of rules. It issues exactly one of three verdicts: ALLOW, HOLD, or REJECT. Every verdict is logged with a verifiable evidence record that cannot be altered after the fact.

What Is Currently Built and Working

The Enforcement Core

- › 12 invariants — non-negotiable rules every request must pass before ALLOW is issued
- › Three and only three outcomes: ALLOW, HOLD, REJECT
- › Fail-closed: any unexpected condition produces REJECT, never ALLOW
- › AI cannot authorize its own requests — hard rule, not a configuration option
- › Evidence bundle produced for every decision — a structured, verifiable record
- › SHA-256 hash-chained audit log — deletions or alterations break the chain and fail verification
- › Replay verification — any prior decision can be re-examined for consistency
- › Diagnostic output — every HOLD and REJECT includes a specific reason code and explanation

Test Coverage

- › 372 tests passing, 0 failing, across 15 test files
- › 66 adversarial tests designed specifically to break or bypass the enforcement
- › 27 misuse-scenario tests based on documented AI governance failure patterns
- › 25 contextual boundary tests covering edge cases and input combinations
- › 15/15 independent audit checks passing (automated, re-runnable by any reviewer)

The Review Portal

- › Live at cerbaseal.replit.app — reviewers can observe the system running in real time
- › 4 portal pages: Review, Pilot Readiness, Security Controls, Deployment Posture
- › All portal claims are backed by tests — a claim that disappears from a page fails a test

What Is Demo-Only

DEMO INFRASTRUCTURE — NOT CLIENT INFRASTRUCTURE

cerbaseal.replit.app runs on Replit's servers. It is appropriate for Olivia's technical review. It is not appropriate for real client data or production decisions. It is a demonstration surface, not a deployment.

What Is Not Yet Implemented

- › Persistent storage — the audit log is in-memory and is lost on process restart
- › Cryptographic signing — the evidence chain is hash-consistent but not key-signed or legally attested
- › Non-Replit deployment — no deployment outside the demo environment has been executed
- › Client-specific workflow configuration — no external client workflow has been set up
- › Third-party security review — all security review to date is internal
- › Production hardening — no container, no infrastructure configuration, no deployment runbook
- › Signed commercial agreement — no pilot client currently exists

What "Pilot-Ready" Actually Means

THE CORRECT DEFINITION

Pilot-ready means: one client, one workflow, one controlled environment, no production decisions, defined success criteria, and a signed agreement in place before a single piece of real data is touched. It does not mean production-ready. The enforcement core is sound. The deployment infrastructure is the gap.

Prerequisites Before Any Pilot Can Begin

- › Signed working agreement: scope, evidence ownership, liability boundary, support terms
- › Persistent storage implemented — audit log must survive process restart
- › Client deployment environment identified, provisioned, and reviewed
- › One specific workflow defined and agreed with the client in writing
- › Data Processing Agreement if any EU client data is involved
- › Success criteria documented and signed — what does "governance working" look like?

WHAT TO SAY ON THE CALL — SECTION 1

"The enforcement core is called CerbaSeal — there is no component called VeraSeal in this build. What exists today is a working governance engine: 372 passing tests, 15 independent audit checks, 12 hard rules that every request must pass. The live demo is not connected to any client data — it is a demonstration. Pilot-ready, as I define it, means one workflow, one client, controlled environment, no production decisions, and a signed agreement before we touch anything real. The primary remaining build item before a pilot is persistent audit storage — the log needs to survive a server restart. That is bounded work, not a redesign."

Olivia's Question: "Can CerbaSeal be deployed in a client-controlled or EU-hosted environment?"**ARCHITECTURE SUPPORTS IT**

CerbaSeal makes no outbound network calls, has no cloud dependencies, and requires no external services of any kind. It runs as a Node.js library. Wherever Node.js runs, CerbaSeal runs. EU hosting is architecturally clear. The caveat is precise: it has never been deployed outside Replit. The path exists. The execution has not happened.

What Has Been Confirmed

- › Zero outbound network calls in any enforcement code path — confirmed by source code review
- › Zero external API dependencies — confirmed by full dependency audit
- › No cloud SDK, no authentication provider, no database driver, no telemetry
- › Four deployment modes documented: embedded library, internal HTTP service, sidecar, air-gapped
- › Mode C (client-controlled environment) is the documented preferred path for EU pilots
- › No geographic restrictions in the code — runs wherever Node.js is present

What Has Not Been Confirmed

- › No EU deployment has been executed — this would be the first
- › No Dockerfile or container configuration exists
- › No deployment runbook or step-by-step operational guide exists
- › No Data Processing Agreement template exists
- › No GDPR analysis has been completed
- › No legal review of EU jurisdiction evidence retention requirements has been done

The Four Deployment Modes

MODE	DESCRIPTION	EU SUITABILITY
A — Embedded Library	CerbaSeal imported directly inside the client service at the decision point. Lowest overhead. Requires Node.js integration.	Suitable
B — Internal HTTP Service	CerbaSeal runs as an internal enforcement service. Clean separation. Requires internal network controls.	Suitable
C — Client-Controlled Env	Temporary pilot environment operated and controlled by the client. Preferred EU path.	Preferred
D — Air-Gapped	Fully offline, no network connection. Maximum isolation for high-regulation contexts.	Maximum isolation

Data Residency — What This Means For Line Axia

Data residency is a legal requirement for EU firms handling EU client data, not a preference. The question is: does data ever leave the environment you control?

CerbaSeal's answer: if deployed in EU-controlled infrastructure, data does not leave. The system calls nothing external. It sends no telemetry. Once installed, it requires no network connectivity. Data residency is entirely determined by where you place the deployment.

THREE PREREQUISITES BEFORE EU PILOT EXECUTION

(1) A Data Processing Agreement must be signed between the parties. (2) The specific EU hosting environment must be reviewed before real data enters it. (3) A legal review of EU evidence retention requirements must be completed. None of these have been done. All three are prerequisites, not optional steps.

EU AI Act — What Is Relevant

The EU AI Act requires verifiable audit trails for high-risk AI systems. CerbaSeal produces a structured, hash-chained audit trail for every decision. Relevant gap: the chain is hash-linked for tamper detection, but not HMAC-signed or externally attested. For formal EU AI Act compliance, signed evidence would be required. This is a documented future requirement. For a pilot evaluation, the existing audit chain is sufficient to demonstrate the governance model.

WHAT TO SAY ON THE CALL — SECTION 2

"The architecture supports EU deployment — there are no external calls, no cloud dependencies, nothing that leaves the environment you deploy it in. The preferred pilot approach is Mode C: you control the hosting, you control the data. What I want to be precise about: I have not deployed CerbaSeal outside Replit yet. The first client deployment would be the first deployment anywhere. Before touching real data, we need a DPA in place and the deployment environment reviewed. Those are prerequisites I would insist on — not obstacles to negotiate around."

OPERATIONAL ROLE DURING A PILOT

Olivia's Question: "What would your operational role look like during a pilot?"

Week 1 — Scoping and Baseline (Highest Intensity)

- › Kickoff call (60 minutes): identify the workflow, define success criteria, agree the authority model
- › Deploy CerbaSeal in the agreed pilot environment
- › Execute baseline enforcement scenarios: REJECT, HOLD, ALLOW — confirmed in client context
- › Produce and sign the pilot scope document — the written contract for what is and is not covered
- › Deliver: workflow map, authority matrix, baseline test scenarios, agreed success metrics

Ongoing — Weekly Rhythm

- › 30-minute review call every week: open issues, resolved issues, enforcement metrics
- › Email support for questions and clarifications
- › Tracked issue queue: every issue receives an ID, severity, status, and documented resolution
- › Weekly status update: open, resolved, and deferred items
- › Decision log: every governance interpretation or scope decision is written down

Documented Response Commitments

PRIORITY	TRIGGER	COMMITMENT
P1 — Critical	Pilot environment down or gate not producing outcomes	Same business day
P2 — Major	Enforcement behavior contradicts documented invariants	Within 24 hours
P3 — General	Documentation question, configuration question, clarification	Within 3 business days
P4 — Enhancement	Request for something outside the agreed pilot scope	Reviewed at weekly planning

"Response" means: issue acknowledged, severity confirmed, investigation begun. Resolution timelines are communicated once the scope of the root cause is understood.

Unavailability Model (Up To 48 Hours)

WHAT CONTINUES WITHOUT FOUNDER INVOLVEMENT

Demo environment, all documentation, security docs, review portal, proof snapshots, invariant registry — all remain accessible. The audit can be re-run independently: "pnpm audit:repo" executes all 15 checks. "pnpm verify:proof" verifies the snapshot has not been altered. All evidence output is human-readable.

WHAT PAUSES DURING UNAVAILABILITY

New issue investigation requiring code changes, configuration changes, and scheduled review calls. Beyond 48 hours: no formal contingency exists. This is an honest limitation of a solo-founder engagement and must be addressed in the working agreement if Line Axia requires a stronger continuity guarantee.

What Is Explicitly Out Of Scope

- › Custom feature development beyond the agreed pilot scope
- › Production deployment work — pilot environment only
- › Legal or regulatory compliance opinions
- › Integration engineering into Line Axia's internal systems
- › Data migration, schema design, or data modeling for production use
- › Indefinite open-ended support beyond the defined pilot period
- › New workflow classes not defined at kickoff

What Is Delivered At Pilot Completion

- › Final findings report: governance outcomes observed, issues encountered, resolutions documented
- › Governance assessment: did the workflow get governed as agreed?
- › Identified gaps: what CerbaSeal does not yet do that production use would require
- › Recommended next steps: specific and bounded, not a sales document
- › All evidence bundles produced during the pilot
- › Technical summary: architecture decisions, invariants exercised, enforcement metrics

ARTIFACT OWNERSHIP

Every document and artifact produced during the pilot belongs to the client. Nothing is withheld.

WHAT TO SAY ON THE CALL — SECTION 3

"Week one is my most intensive period — scoping, deployment, baseline scenarios, signed scope document. After that: a 30-minute weekly call, email support, and a tracked issue queue with defined response times. Same business day for a system outage, 24 hours for a rule violation, 3 days for general questions. I am a solo founder and I want to be explicit about what that means. I have built the system to be self-documenting — it explains its own decisions. What I cannot offer is 24/7 on-call support. If that is a requirement, it needs to be scoped and priced as part of the agreement."

Olivia's Question: "What is your realistic capacity for a pilot engagement?"**SOURCING NOTE**

Capacity and schedule constraints are not stored in the repository. This section provides structure for an honest answer based on what the pilot operations model documents. Jesse provides the specifics.

What The Pilot Requires — Hour Estimates**Week 1 (Peak Demand)**

- › Kickoff call: ~1 hour
- › Deployment and baseline scenario execution: 4–8 hours (depends on client environment complexity)
- › Pilot scope document, workflow map, authority matrix, baseline scenario set: 4–6 hours
- › Total week 1 estimate: 10–15 hours of active founder work

Ongoing — Weeks 2 Onward (Steady State)

- › 30-minute weekly review call
- › Issue queue management: 1–3 hours per week depending on issue volume
- › Email support: light in a well-scoped pilot
- › Steady-state estimate: 3–5 hours per week in a normal week

Issue Spikes (Infrequent But Must Be Planned For)

- › P1 (system down): potentially a half-day of investigation and resolution
- › P2 (rule violation): 2–4 hours of root-cause analysis
- › These are infrequent in a controlled, scoped pilot — but cannot be budgeted as zero

Constraints That Must Be Named On The Call

- › Solo founder — no second engineer as a backup for live issue response
- › The 48-hour self-service model is the documented unavailability contingency
- › No formal contingency beyond 48 hours exists
- › Active pilot would be the first client deployment outside the demo environment
- › No managed infrastructure exists — deployment is a manual, per-engagement process today

Infrastructure Requirements**MINIMAL FOOTPRINT**

Node.js runtime (standard in most infrastructure), pnpm (or npm), no cloud accounts, no paid services, no proprietary tooling. The client provides the hosting environment for Mode C deployments. Founder needs: a standard developer workstation and email.

What Support You Would Need From Line Axia

- › IT team to provision the pilot deployment environment
- › Engineering contact to construct workflow requests in the correct input format
- › Legal review from the Line Axia side for DPA and working agreement

WHAT TO SAY ON THE CALL — SECTION 4

"Week one is 10 to 15 hours of active work — scoping, deploying, running baseline scenarios. After that I run at 3 to 5 hours a week in a normal week. I don't have competing pilot deployments right now. I am a solo founder. I have defined response times, a documented self-service model, and a system built to be readable without me. What I cannot offer is 24/7 on-call support — if that is a hard requirement, it needs to be structured and priced explicitly."

Olivia's Question: "Are there any open-source components or third-party dependencies in the deployment stack we should be aware of?"

CORRECTED EXECUTIVE SUMMARY

The CerbaSeal-Core enforcement library has zero runtime dependencies. None. The library itself, as installed into a client environment, brings no third-party packages with it. The demo environment (cerbaseal.replit.app) uses one additional package to execute TypeScript directly — tsx, MIT licensed. That package is part of the demo runner, not the enforcement library. No cloud services. No external APIs. No telemetry. Zero external service calls at runtime.

The Two-Package Picture — Explained

CerbaSeal-Core (The Enforcement Library — What Clients Install)

CerbaSeal-Core is a pure TypeScript library. Its node_modules directory in the repository contains only development and test tooling: vitest, vite, rollup, typescript, chai. None of these ship with a client installation. The production enforcement library itself has zero runtime dependencies.

CLIENT DEPLOYMENT SUPPLY CHAIN

Node.js runtime (client-provided) + CerbaSeal-Core source. That is the complete deployment stack. No additional packages required.

cerbaseal-review (The Demo/Review Wrapper — cerbaseal.replit.app)

The demo environment that Olivia can view at cerbaseal.replit.app runs on a separate package — cerbaseal-review — which uses tsx to execute TypeScript directly without a compile step. This is a development convenience, not part of a client deployment.

PACKAGE	VERSION	LICENSE	SCOPE	CLIENT DEPLOYMENT?
tsx	4.21.0	MIT	Demo runner	No — demo only
esbuild	0.27.x	MIT	Used by tsx internally	No — demo only
get-tsconfig	4.13.x	MIT	Used by tsx internally	No — demo only
resolve-pkg-maps	1.0.0	MIT	Used by get-tsconfig	No — demo only

License Summary

LICENSE	PRESENT WHERE	COMMERCIAL RISK
MIT	All runtime packages in demo wrapper	None — no restrictions on commercial use
Apache 2.0	TypeScript compiler (dev/build only)	None — no restrictions relevant here
MPL-2.0	lightningcss (dev/build only, not deployed)	None — file-scoped, does not affect CerbaSeal source
GPL / AGPL	NOT PRESENT anywhere in the dependency tree	Not applicable

COPYLEFT DETERMINATION

Zero copyleft-licensed software in any client deployment. All runtime licenses are MIT. No source disclosure obligation to clients. GPL is not present anywhere in the dependency tree.

External Services Audit

Cloud platform dependencies	None
SaaS API dependencies	None
Outbound network calls	None — confirmed by source code review
External database connections	None
Telemetry or analytics	None
Identity / auth providers	None
CDN dependencies	None

Answers To Likely Supply Chain Questions

Can CerbaSeal-Core run entirely in a client-controlled environment?

Yes. No component requires a Lamont Labs–operated service after installation.

Can it run in EU-hosted infrastructure?

Yes, architecturally. No geographic restrictions exist in the code. Caveat: not yet executed.

Does it require US-operated services?

No. npm is used at install time only and can be replaced with a private registry or offline bundle.

Does it require internet after deployment?

No. Once installed, enforcement runs offline. No connectivity required.

What does a client security review need to cover?

Node.js runtime (client-provided) + CerbaSeal-Core source. If the demo runner is in scope: add tsx and its three transitive packages.

60-SECOND VERBAL ANSWER — SECTION 5

"The CerbaSeal enforcement library has zero runtime dependencies — nothing ships with it. The demo you're looking at right now uses one package called tsx to run TypeScript directly, which is MIT licensed. That's part of the demo environment, not the library. No cloud services, no external APIs, no telemetry — nothing calls outside your environment. All licenses are MIT. No GPL anywhere. If your security team needed to review a client deployment, the surface is Node.js plus CerbaSeal source. That is it."

25 MOST LIKELY FOLLOW-UP QUESTIONS

Ranked by probability. Based on documented repository gaps and what a technically rigorous CTO would probe after reviewing the materials.

Q01 "Can you show CerbaSeal running on infrastructure we control — not Replit?"

WHY SHE ASKS: Replit is a developer sandbox. Any enterprise CTO will require evidence that the system works outside a shared demo host.

YOUR ANSWER: "Not yet — the first non-Replit deployment has not happened. I can walk you through precisely what a Mode C deployment to your environment looks like, and we can execute that as the first step of a pilot. The architecture has no barriers. The work is in the first execution."

DO NOT SAY: Do not imply this has been done. It has not.

Q02 "What happens to the audit log if the server restarts?"

WHY SHE ASKS: The single most important technical gap. Any reviewer reading the security brief will find it immediately.

YOUR ANSWER: "The audit log is currently in-memory. A process restart clears the log for that session. This is my highest-priority build item before any pilot. The fix is file-backed or database-backed storage — bounded work, not a redesign. This must be in place before client data enters the system."

DO NOT SAY: Do not minimize this. It is a real gap. Naming it directly builds more trust than hedging.

Q03 "Who else has reviewed the security of this system?"

WHY SHE ASKS: A governance tool for a regulated sector without external validation is a red flag for a sophisticated buyer.

YOUR ANSWER: "No third-party review has been completed. All security review is internal. I have a security brief that documents every known limitation accurately — I'd rather you read it than have false confidence. External review is on the roadmap before any production use."

DO NOT SAY: Do not imply any external validation has occurred.

Q04 "What is your contingency if you are unavailable — hit by a bus?"

WHY SHE ASKS: Standard solo-founder diligence. She needs to know the engagement survives your absence.

YOUR ANSWER: "Documented up to 48 hours. The system re-audits itself, the proof verifies independently, all documentation is self-contained. Beyond 48 hours, I do not have a backup engineer today. If Line Axia requires a stronger continuity guarantee, that needs to be structured in the agreement."

DO NOT SAY: Do not claim a backup you do not have.

Q05 "What version are we freezing for the pilot, and how do updates work?"

WHY SHE ASKS: Any responsible buyer will want to know they are not signing up for a moving target.

YOUR ANSWER: "We freeze a specific version at pilot start — v0.1.0 today, or a later agreed snapshot. Any update during the pilot requires a change log entry and your written sign-off. No enforcement behavior changes without notice."

DO NOT SAY: Do not imply a formal update management system exists that does not.

Q06 "Can you show me a GDPR analysis?"

WHY SHE ASKS: Line Axia is EU-based with EU clients. GDPR compliance is not optional.

YOUR ANSWER: "I do not have a completed GDPR analysis. The architecture keeps data entirely within the deployment environment — no external calls, no telemetry. Whether evidence bundles constitute personal data under GDPR depends on what workflows CerbaSeal governs. That analysis requires legal review — and a DPA between us — before real data enters the system."

DO NOT SAY: Do not claim GDPR compliance.

Q07 "Does CerbaSeal evaluate the content of the policy document it references?"

WHY SHE ASKS: A technically sophisticated reviewer will notice that policyPackRef is required but its content is not interpreted. This looks like a gap without an explanation.

YOUR ANSWER: "CerbaSeal requires a policy pack reference — a pointer to the governing policy. It checks that the reference exists. It does not evaluate the content of the policy document. Policy content interpretation is handled upstream by the client's system. CerbaSeal enforces the governance layer: is approval present, is the actor authorized, is the action known."

DO NOT SAY: Do not imply CerbaSeal reads or interprets policy documents.

Q08 "Do you have cyber liability insurance?"

WHY SHE ASKS: Standard enterprise diligence for a governance product in a regulated sector.

YOUR ANSWER: Jesse answers directly. If you have it, state the coverage. If not: "I do not currently have a cyber liability policy. For a production engagement in a regulated sector, that is something I would address before a signed production agreement."

DO NOT SAY: Do not bluff on this.

Q09 "What does the working agreement look like?"

WHY SHE ASKS: If this call goes well, the next thing is a term sheet. She will want to know you have thought about this.

YOUR ANSWER: "The prerequisites are documented: scope, evidence ownership, liability boundary, support terms, DPA if applicable, version freeze policy. The two items I'd want clear early are: what constitutes a change request and what it costs, and who owns the evidence artifacts. Governing law must be defined before anything is signed."

DO NOT SAY: Do not promise a draft agreement you do not have ready to produce.

Q10 "How do we know the audit chain was not fabricated?"

WHY SHE ASKS: The correct adversarial question for any governance system.

YOUR ANSWER: "The chain uses SHA-256 hash linking — each entry contains the hash of the previous entry. Deleting or altering any entry breaks the chain and fails verification. What it does not do is HMAC signing: a technically sophisticated attacker controlling the entire system could recompute the hashes. For legal-weight evidence, signing or external attestation would be required. That is on the gap list. For a pilot evaluation, the hash chain is sufficient to demonstrate consistency."

DO NOT SAY: Do not claim cryptographic signing exists.

Q11 "What is your pricing model?"

WHY SHE ASKS: If the technical case holds, she will move to commercial terms.

YOUR ANSWER: Jesse answers directly. Suggested framing: "Fixed-fee structure for a bounded pilot — cleaner for both sides. Week one is the highest-effort period. Ongoing is lighter. Change requests priced separately. Percentage structures create ambiguity on a v0.1 product."

DO NOT SAY: Do not give a number you have not thought through in advance.

Q12 "What happens when CerbaSeal encounters a request type it does not recognise?"

WHY SHE ASKS: Unknown inputs are where governance systems tend to fail silently.

YOUR ANSWER: "Unknown action classes produce a REJECT with a documented reason code. Unknown structural inputs trigger a fail-closed REJECT. The system does not guess or default to ALLOW. If it cannot categorize the request, it blocks it."

DO NOT SAY: Do not imply all unknown inputs are handled with equal precision.

Q13 "Can CerbaSeal integrate with our existing audit or logging infrastructure?"

WHY SHE ASKS: Line Axia has existing systems and will want to know where CerbaSeal fits.

YOUR ANSWER: "Not out of the box — that is pilot-scoped integration work. CerbaSeal produces structured evidence bundles and a hash-linked log that can be exported and ingested into existing systems. The integration layer between CerbaSeal's output format and your infrastructure would be defined during scoping."

DO NOT SAY: Do not imply pre-built integrations exist.

Q14 "How does CerbaSeal scale to multiple workflows or multiple clients?"

WHY SHE ASKS: If Line Axia wants to roll this out across their client base, they need to understand the expansion story.

YOUR ANSWER: "Multi-client support is not implemented. The first pilot is explicitly one client, one workflow. Expansion to multiple workflows or clients is a next-phase discussion after a successful pilot demonstrates the model. The architecture does not prevent it — but it has not been built or tested."

DO NOT SAY: Do not imply multi-client capability exists.

Q15 "What does a failed pilot look like, and what do we owe each other?"

WHY SHE ASKS: A serious CTO always asks about the failure scenario.

YOUR ANSWER: "If the pilot does not meet the agreed success criteria, you receive a final findings report documenting what worked, what did not, and why — with specific recommendations. You keep all artifacts. The agreement must define what 'failure' means, what each party owes, and any fee adjustment. I would rather define that before we start."

DO NOT SAY: Do not promise a refund policy you have not agreed to.

Q16 "Is there a product roadmap? What does CerbaSeal look like in 12 months?"

WHY SHE ASKS: She is evaluating this as a long-term partnership, not a one-time experiment.

YOUR ANSWER: "There is a documented gap list: persistent storage, cryptographic signing, identity provider integration, third-party security review, multi-client support. A 12-month roadmap would be shaped by what the pilot reveals. I would rather commit to specific outcomes from pilot findings than over-promise on a schedule."

DO NOT SAY: Do not commit to a product timeline you cannot defend.

Q17 "What are the performance characteristics? How fast is the enforcement gate?"

WHY SHE ASKS: For production AI governance in a workflow system, latency matters.

YOUR ANSWER: "372 tests complete in under 300 milliseconds total. Individual gate evaluations are sub-millisecond. There are no network calls in the enforcement path. Formal load and stress testing has not been done — that would be part of pre-production qualification."

DO NOT SAY: Do not claim production-validated performance figures.

Q18 "How do we know your documentation matches what the code actually does?"

WHY SHE ASKS: A sophisticated reviewer is suspicious of documentation that is too polished.

YOUR ANSWER: "Several of the 15 independent audit checks specifically test this: portal claims are verified against test output, the test count matches the actual run, every invariant is linked to a covering test, and forbidden phrases that would indicate overclaiming are scanned. The documentation is tested against the code — not maintained separately."

DO NOT SAY: Do not claim perfect documentation coverage.

Q19 "What if our client's AI system finds a bypass?"

WHY SHE ASKS: Adversarial question about bypass resistance — essential for a governance product.

YOUR ANSWER: "66 of the 372 tests are explicitly designed to break or bypass the enforcement. Core protections are structural: AI cannot authorize itself, forged results are rejected by an issuance registry, unexpected exceptions fail closed. The known weaker point: caller-supplied fields (loggingReady, prohibitedUse) are trusted without independent verification. That is documented and requires upstream trustworthiness. For a controlled pilot it is manageable. For production it requires additional verification."

DO NOT SAY: Do not claim the system is bypass-proof.

Q20 "What happens if one of our clients' regulators audits the system?"

WHY SHE ASKS: EU AI Act and financial regulation create audit obligations that flow downstream to vendors.

YOUR ANSWER: "Every decision has a reason code, an evidence bundle, and a verifiable chain of custody — designed to be auditable. What a regulator would not yet have: third-party security review, cryptographic signatures on the evidence, and a formal compliance certification. Those are the three items I would want in place before any regulator looks at a production deployment."

DO NOT SAY: Do not claim regulatory compliance.

Q21 "What makes CerbaSeal different from something we could build internally?"

WHY SHE ASKS: Any well-resourced firm may consider building in-house.

YOUR ANSWER: "Build vs. buy is a legitimate question. What you get with CerbaSeal: an adversarially tested enforcement layer — 66 bypass attempts, 12 hard invariants, a hash-chained evidence system, and a clear boundary between enforcement and business logic. What you would build from scratch: all of that, plus the test suite, plus the invariant model. The real question is whether governance enforcement is core to what Line Axia builds or core to what Line Axia sells."

DO NOT SAY: Do not dismiss in-house engineering capability.

Q22 "How do we handle a CerbaSeal block that turns out to be wrong?"

WHY SHE ASKS: False positives in a governance system are operationally painful.

YOUR ANSWER: "Every HOLD and REJECT includes a diagnostic report identifying exactly which rule was triggered. For a HOLD: a human reviewer reads the diagnostic, decides to approve or defer, and the system logs that decision. For a REJECT that appears incorrect: the issue enters the tracked queue, root cause is investigated, and if the rule is wrong the fix is documented and scoped. There is no override button — by design. Every outcome is logged."

DO NOT SAY: Do not imply there is an administrative override.

Q23 "Can you tell us about the a16z application or other active partnerships?"

WHY SHE ASKS: Potential conflict with an exclusivity arrangement. Strategic, not technical.

YOUR ANSWER: Jesse answers directly. Know your position on active investor conversations before the call.

DO NOT SAY: Do not get caught in an inconsistency about current conversations.

Q24 "What governing law would you want for the agreement?"

WHY SHE ASKS: France-based firm with EU clients. They will want EU or French law. Jesse needs a clear position going in.

YOUR ANSWER: Jesse answers directly. Suggested framing: "I'm open to French law or EU law given your client base. What I'd want clearly defined regardless of jurisdiction: what constitutes a change request, evidence ownership, and liability cap. Those matter more to me than the jurisdiction choice."

DO NOT SAY: Do not dismiss the jurisdiction question — Tina Simpson will make it a point.

Q25 "What would 12-month EU exclusivity actually mean and what would it cost?"

WHY SHE ASKS: If the conversation reaches exclusivity, she will want to understand what she is buying and at what cost.

YOUR ANSWER: "EU exclusivity means I don't deploy CerbaSeal for another EU client for 12 months. What I'd want defined: what counts as 'EU' for this purpose, what event triggers a right-of-first-refusal to extend, and what terminates exclusivity if the engagement is inactive. The commercial value of exclusivity is a separate negotiation from the pilot fee — I'd rather not bundle them."

DO NOT SAY: Do not commit to exclusivity terms on the call. Get it in writing first.

FOUNDER CHEAT SHEET

Read this the morning of the call. One question at a time. Plain English. No technical jargon required.

01 "Where is CerbaSeal / what is VeraSeal?"

SHORT: "CerbaSeal is the enforcement system. There is no component called VeraSeal in this build."

HONEST: "What I have is a working governance engine — 372 tests, 15 independent checks — not yet deployed outside a demo environment."

DANGER: "VeraSeal is our..." — stop. Do not finish that sentence.

02 "Is this EU-deployable?"

SHORT: "Architecturally yes — no external calls, no cloud, runs wherever Node.js runs."

HONEST: "I have not deployed it outside Replit yet. First client deployment would be the first deployment anywhere."

DANGER: "We have tested this in EU environments." — false.

03 "What do you actually do during the pilot?"

SHORT: "Intensive week one, then weekly 30-minute calls and tracked email support."

HONEST: "I'm a solo founder. 48-hour self-service model documented. Beyond that, no backup engineer today."

DANGER: "I'm available 24/7." — you are not.

04 "How available are you?"

SHORT: "3–5 hours per week after week one, defined response times for every issue severity."

HONEST: "Solo founder. If unavailable, the system runs without me for 48 hours. Beyond that is a documented risk."

DANGER: "Don't worry, I'll always be there." — do not promise what you cannot guarantee.

05 "Any open-source concerns?"

SHORT: "CerbaSeal-Core has zero runtime dependencies. The demo runner uses tsx — MIT licensed."

HONEST: "No GPL anywhere. Nothing ships with the library itself. Cleanest possible supply chain story."

DANGER: "It's built entirely from scratch with no dependencies at all." — tsx exists. Name it for the demo.

06 "What happens to the audit log on restart?"

SHORT: "It's in-memory today. Persistent storage is my top pre-pilot build item."

HONEST: "This is a real gap. It must be fixed before any client data enters the system. No exceptions."

DANGER: "The evidence is fully durable." — in-memory means lost on restart. Do not say this.

07 "Has anyone else reviewed your security?"

SHORT: "No external review yet. I have a security brief documenting every known limitation."

HONEST: "All review is internal. External review is a prerequisite before production use."

DANGER: "We've been reviewed by..." — do not name anyone unless it is true.

08 "Is the audit chain cryptographically signed?"

SHORT: "Hash-linked for tamper detection. Not key-signed. Proves consistency, not origin."

HONEST: "HMAC signing is on the gap list. For a pilot evaluation the hash chain is sufficient."

DANGER: "The evidence is cryptographically verified." — hash-chained is not the same as signed.

09 "Do you have existing clients?"

SHORT: "No. This conversation is the beginning of that."

HONEST: "No signed pilot client. No commercial agreement. Proof-stage product."

DANGER: "We're in conversations with several firms." — do not imply clients you do not have.

10 "Is CerbaSeal production-ready?"

SHORT: "No. Pilot-ready: one workflow, controlled environment, no production decisions."

HONEST: "Production requires persistent storage, cryptographic signing, external security review. Those are the gaps."

DANGER: "We're very close to production-ready." — you are not. Say exactly what you are.

PRE-CALL CHECKLIST

[CONFIRMED]	372 tests passing, 0 failing — run pnpm test to confirm before the call
[CONFIRMED]	15/15 audit checks — run pnpm audit:repo to confirm
[CONFIRMED]	LICENSE file exists and is properly formed (proprietary, Lamont Labs)
[CONFIRMED]	Demo live at cerbaseal.replit.app — open it before the call starts
[DO BEFORE]	Know your position: cyber liability insurance, governing law preference, exclusivity terms
[DO BEFORE]	Know your estimate for persistent storage build: 2–5 days file-backed, longer for production-grade
[DO BEFORE]	Run through Section 6 questions verbally — out loud, not just in your head
[ON THE CALL]	If she says VeraSeal: correct it once, move on, do not labour the point
[ON THE CALL]	Lead with what is real. Enforcement core, tests, audit checks are all real.
[ON THE CALL]	Do not overclaim. Every claim you make will be checked by Tina Simpson.
[AFTER THE CALL]	Follow up in writing: confirmed pilot shape, prerequisites, and next steps within 24 hours

CLOSING POSITION — THE HONEST COMPETITIVE ADVANTAGE

The competitive position is not "we are production-ready." The competitive position is: the enforcement logic that most governance products describe in slide decks is implemented, tested, and observable running right now. The gaps are documented accurately, not hidden. A pilot is the right next step — bounded scope, defined success criteria, signed agreement first. That is a stronger position than overclaiming. Olivia will verify every claim made on this call. The ones above will hold.